TOPIC 3: PERSONAL COMPUTER (PC) SECURITY CONTROLS

Official Undergraduate Lecture Slide Deck (Academic Year 2026/2027)

- Curriculum Coverage: Hard Disk Passwords (3.1) | BIOS/UEFI & TPM (3.2) | Access Controls (3.3)
- **Course Instructor: Madam Bertha Msuliche Lebalwa (MSc)**
- Assessment Structure: 2 Assignments (5%), 2 Tests (15%), Practical Report (10%), Practical Test (30%), UE (40%)*

**Assessment weightings are subject to adjustment by the course instructor.*

Topic 3: Lecture Outline & Learning Roadmap

Personal Computer Security Controls, Firmware & Access Models (Coverage: 3.1, 3.2, 3.3)

- Section 3.1: Hard Disk & Storage-Level Security Controls
  - ATA security feature set: User vs Master passwords; Self-Encrypting Drives (SED / Opal)
  - Whole Disk Encryption (WDE): BitLocker, LUKS, FileVault; Key management hierarchies
  - Data sanitization standards: NIST SP 800-88 Rev 1 (Clear, Purge, Destroy); Crypto-erase
- Section 3.2: BIOS & UEFI Firmware Security Controls
  - Legacy BIOS limitations vs UEFI architecture (GPT, 64-bit mode, modular drivers)
  - Firmware password hierarchy: Supervisor vs User/Power-On passwords
  - UEFI Secure Boot Architecture: PK, KEK, db, dbx; The cryptographic chain of trust
  - Trusted Platform Module (TPM 2.0): EK, SRK, PCR registers, Measured Boot & Attestation
- Section 3.3: Operating System Login Passwords & User Access Controls
  - Authentication factors: Something you know, have, and are (Biometrics FAR/FRR)
  - Password entropy math, hashing algorithms (SHA-256 vs bcrypt/Argon2id)
  - Access Control Models: Discretionary (DAC - POSIX), Mandatory (MAC - SELinux), and RBAC

SECURITY PRINCIPLE

Security is a system of defense-in-depth: protecting hardware, firmware, storage encryption, and OS access privileges in cohesive layers.

Topic 3: Intended Learning Outcomes (ILOs)

Core Security Competencies for Undergraduate Students

- Differentiate between storage-level ATA passwords, Whole Disk Encryption, and OS login passwords.
- Analyze UEFI Secure Boot key hierarchies (PK, KEK, db, dbx) and explain the verified boot chain.
- Explain the cryptographic role of TPM 2.0 in Measured Boot and BitLocker volume key sealing.
- Calculate password entropy in bits and determine brute-force cracking resistance.
- Formulate appropriate NIST SP 800-88 sanitization procedures for SSDs versus magnetic HDDs.
- Apply Discretionary (DAC) and Mandatory (MAC) access control models in Windows and Linux environments.
- Design a hardened microcomputer workstation deployment for confidential university examinations.

Multi-Layered Personal Computer Security Stack

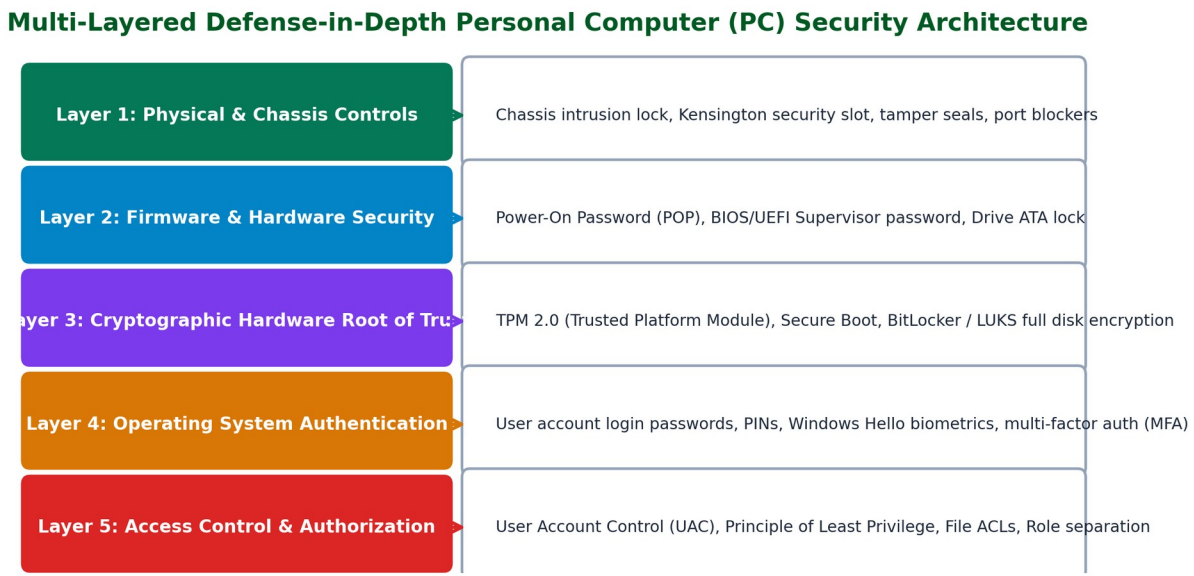


Figure: The multi-layered PC security defense model from physical chassis to application access controls.

ARCHITECTURAL ANALYSIS & PRINCIPLES

- Layer 1 - Physical & Storage Security: Chassis locks, Kensington cables, ATA disk locks, Full Disk Encryption.
- Layer 2 - Firmware & Hardware Root of Trust: UEFI Supervisor passwords, Secure Boot, TPM 2.0 PCR sealing.
- Layer 3 - Operating System Security: Kernel integrity, secure login, PAM authentication, Least Privilege access.
- Layer 4 - Access Control & Encryption: Discretionary Access Control (POSIX permissions), MAC, encrypted filesystems.

Storage Security: ATA Security Feature Set

Drive-Level Firmware Locking and Self-Encrypting Drives

• ATA Storage Security Commands: Built into drive controller firmware (independent of operating system).

• Password Hierarchy:

- User Password: Required to unlock drive for normal read/write operations at system boot.
- Master Password: Set by system administrators; allows drive unlocking or secure data erasure.

• Security Modes: High Security (User password can be cleared by Master password) vs Maximum Security (User password cannot be cleared; drive must be Secure Erased).

• Critical Vulnerability: Standard ATA passwords transmit password hashes in plaintext across the SATA/NVMe bus; vulnerable to hardware bus sniffing.

• Self-Encrypting Drives (SED): Opal standard; drive hardware automatically encrypts all written data using internal AES engine; passwords unlock decryption key.

Whole Disk Encryption (WDE): BitLocker & LUKS

Logical Sector-Level Cryptography Protecting Data at Rest

• The Physical Theft Threat: If a laptop is stolen, an attacker can extract the drive and mount it in another PC, completely bypassing Windows/Linux login passwords.

• Whole Disk Encryption Architecture:

- Encrypts every single sector on the storage volume (operating system files, swap files, user documents).
- Uses high-speed hardware-accelerated AES-XTS (128 or 256 bits).

• Microsoft BitLocker Key Architecture:

- Full Volume Encryption Key (FVEK): Encrypts actual disk sectors.
- Volume Master Key (VMK): Encrypts the FVEK; sealed inside the TPM chip.
- TPM Unsealing: TPM releases VMK only if Platform Configuration Registers (PCRs) match authorized hardware state.

• Linux dm-crypt / LUKS: Linux Unified Key Setup providing multi-keyslot encryption for root filesystems.

Data Sanitization Standards (NIST SP 800-88 Rev 1)

Clear, Purge, and Destroy: Preventing Post-Decommissioning Leakage

• The Residual Data Threat: Simple OS file deletion or formatting merely clears filesystem metadata; raw data remains recoverable.

• NIST SP 800-88 Categories:

- 1. Clear: Overwriting storage spaces with logical data patterns via standard read/write commands (e.g., single-pass overwrite for HDDs).

- 2. Purge: Applying physical or cryptographic techniques that make data recovery impossible even with laboratory equipment (ATA Secure Erase, Cryptographic Erase).

- 3. Destroy: Physical destruction of media (degaussing for magnetic media, shredding, incineration, chemical disintegration).

• The SSD Overwrite Problem: Traditional multi-pass overwrites (DoD 5220.22-M) fail on SSDs due to wear-leveling spare blocks. Cryptographic Erase (destroying encryption key) is the recognized modern standard.

Firmware Security: Legacy BIOS vs Modern UEFI

The Evolution from 16-bit Real Mode to 64-bit Modular Architecture

- Legacy BIOS (Basic Input/Output System):
  - 16-bit real mode execution; limited to 1 MB addressable memory space.
  - Master Boot Record (MBR) partition table: Maximum 2.0 TB drive capacity, max 4 primary partitions.
  - No built-in cryptographic signature verification; highly vulnerable to bootkits (malicious MBR overwrites).
- UEFI (Unified Extensible Firmware Interface):
  - 32-bit or 64-bit protected mode; direct access to full system RAM.
  - GUID Partition Table (GPT): Up to 9.4 Zettabytes volume capacity, 128 primary partitions.
  - Modular architecture with network stack, graphical setup interface, and UEFI Secure Boot.

Firmware Password Controls & Physical Tampering

Supervisor Passwords, Boot Order Locking & CMOS Physics

- BIOS/UEFI Supervisor (Administrator) Password:
  - Restricts unauthorized access to firmware setup utility; prevents tampering with boot sequence, virtualization, or Secure Boot settings.
- User / Power-On Password:
  - Demands authentication before the firmware initiates hardware POST or boots the operating system.
- Physical Tampering Defenses:
  - Legacy desktop PCs could be bypassed by removing the CR2032 coin-cell battery or shorting the CMOS clear jumper.
  - Modern enterprise laptops store firmware hashes and passwords in non-volatile flash / security chips resistant to battery removal.
  - Chassis Intrusion Switches: Motherboard sensor logs an alert if the physical computer chassis has been opened.

UEFI Secure Boot Architecture & Key Hierarchy

Establishing an Unbroken Cryptographic Chain of Trust

• Core Objective: Guarantees that only cryptographically signed and authenticated bootloaders, drivers, and OS kernels can execute at boot time.

• Secure Boot Key Hierarchy:

- 1. Platform Key (PK): Root of trust held by OEM/hardware manufacturer; controls access to KEK.
- 2. Key Exchange Key (KEK): Authorizes updates to signature databases (db / dbx). Held by Microsoft and OS vendors.
- 3. Allowed Signature Database (db): Contains trusted certificates, SHA-256 hashes of authorized bootloaders and EFI binaries.
- 4. Forbidden Signature Database (dbx): Revocation list containing compromised binaries and revoked signing keys.

• The 'Shim' Bootloader: Lightweight bootloader signed by Microsoft 3rd Party UEFI CA that verifies the GRUB2 bootloader and Linux kernel.

The Trusted Platform Module (TPM 2.0)

Hardware Root of Trust, Cryptographic Co-Processor & Measured Boot

• Definition: Dedicated tamper-resistant cryptographic microchip (discrete dTPM or firmware fTPM) soldered to the motherboard.

• Core Cryptographic Engines: Hardware True Random Number Generator (TRNG), RSA-2048 and ECC key generation, SHA-256 hashing engine.

• Internal Key Infrastructure:

- Endorsement Key (EK): Permanently burnt into silicon during manufacturing; unique device identifier.
- Storage Root Key (SRK): Master key protecting user cryptographic keys.

• Platform Configuration Registers (PCRs 0–23):

- Measured Boot: Each boot component (UEFI code, hardware configuration, bootloader, kernel) hashes the subsequent stage and extends PCRs.
- Key Sealing: Data is sealed against specific PCR values; if firmware or bootloader is altered, PCRs will not match, and TPM refuses to unseal encryption keys.

Authentication Principles & Multi-Factor Models

Something You Know, Have, and Are

• Authentication: The formal process of verifying an entity's claimed identity.

• The Three Classical Factors:

- 1. Knowledge Factor (Something you know): Passwords, passphrases, PIN numbers, security questions.
- 2. Possession Factor (Something you have): Hardware security keys (YubiKey / FIDO2), smartcards, TOTP authenticator app tokens.
- 3. Inherence Factor (Something you are): Biometrics — fingerprints, facial geometry, iris patterns, retinal scans.

• Multi-Factor Authentication (MFA):

- Requires presentation of two or more *different* authentication categories.
- Presenting a password and a PIN is NOT MFA (both are knowledge factors).
- Combining a password (Knowledge) with a FIDO2 token (Possession) provides genuine MFA, eliminating >99% of automated credential theft attacks.

Password Security Engineering & Entropy Mathematics

Calculating Information Density and Brute-Force Feasibility

- Password Entropy Formula: H = L · log₂(N) [measured in bits]:
  - L = Number of characters in password; N = Size of character pool.
  - Lowercase only (a-z): N = 26; Alphanumeric (a-z, A-Z, 0-9): N = 62; Full ASCII keyboard: N = 95.
- Entropy Comparison:
  - 'pass1234' (L=8, N=62): H = 8 · log₂(62) = 8 · 5.954 = 47.6 bits.
  - 'Mkulima#Kwanza@2026!' (L=21, N=95): H = 21 · log₂(95) = 21 · 6.570 = 137.9 bits.
- Brute-Force Search Space: Total combinations = N^L.
  - Modern GPU cluster testing 100 billion SHA-256 hashes/sec cracks 47.6 bits in < 4 minutes.
  - A 137.9-bit password requires over 10²² years to exhaust — mathematically uncrackable.

Cryptographic Password Hashing in Operating Systems

From Insecure MD5 to Salted, Slow-Key Derivation (Argon2id)

• Password Storage Imperative: Operating systems NEVER store user passwords in plaintext; only cryptographic hashes are stored.

• The Role of Salt: A unique random string (e.g., 16 bytes) appended to password before hashing; defeats precomputed Rainbow Table attacks.

• Linux `/etc/shadow` Architecture: `$id$salt$hashed_value`:

- `$1$`: MD5 (legacy, broken); `$5$`: SHA-256; `$6$`: SHA-512; `$y$`: yescrypt.

• Modern Slow Key Derivation Functions:

- bcrypt, PBKDF2, scrypt, and Argon2id (Password Hashing Competition winner).

- Memory-hard and computationally parameterized: Forces GPU cracking rigs to allocate large RAM blocks per guess, neutralizing brute-force parallelization.

Access Control Models: Discretionary vs Mandatory

DAC, MAC, and Role-Based Access Control (RBAC)

- Discretionary Access Control (DAC):
  - Resource owner has full discretion to grant or revoke access permissions to other users.
  - Standard model in Windows NTFS permissions and Linux POSIX permissions (`chmod`, `chown`).
  - Limitation: Vulnerable to Trojan horses executing with owner privileges.
- Mandatory Access Control (MAC):
  - Central security policy enforced by operating system kernel based on security clearances and object sensitivity labels.
  - Users/owners CANNOT override policy (e.g., SELinux - Security-Enhanced Linux, AppArmor).
- Role-Based Access Control (RBAC):
  - Permissions assigned to organizational roles (e.g., 'SUA Exam Officer', 'Lecturer', 'Student'), and users assigned to roles.

Linux Permissions Architecture & Hardening

Octal Representation, Special Bits, and Sudoers Governance

- Permission Triplet: Owner (u), Group (g), Others (o) across Read (r=4), Write (w=2), Execute (x=1):
  - `chmod 755 file.sh` → `rwxr-xr-x` (Owner can read/write/exec; others read/exec).
  - `chmod 640 data.db` → `rw-r-----` (Owner can read/write; group can read; others denied).
- Special Permission Bits:
  - SetUID (4000): Process runs with file owner privileges (e.g., `/usr/bin/passwd`).
  - SetGID (2000): Files created inherit directory's group ownership.
  - Sticky Bit (1000): Only file owner can delete file within directory (e.g., `/tmp`, `chmod 1777 /tmp`).
- Principle of Least Privilege: Administrative tasks executed via `sudo` with exact binary paths logged in `/etc/sudoers`.

Biometric Authentication: Technical Metrics

Balancing Security and Usability in Field Systems

• Biometric Matching Engine: Compares captured live sample with enrolled mathematical template.

• False Acceptance Rate (FAR): Probability that the biometric system incorrectly authorizes an unauthorized imposter (Type II Error - Security failure).

• False Rejection Rate (FRR): Probability that the system incorrectly rejects an authentic registered user (Type I Error - Usability failure).

• Crossover Error Rate (CER) / Equal Error Rate (EER): The operating threshold where FAR equals FRR. Lower CER indicates superior sensor accuracy.

• Liveness Detection: Capacitive pulse sensing, infrared vein detection, and thermal imaging preventing presentation attacks (silicone molds, photographs).

Password Hashing Defenses: Salt and Pepper Architecture

Mitigating Offline Dictionary and Rainbow Table Attacks

• The Rainbow Table Threat: Precomputed lookup tables containing trillions of pre-hashed passwords, enabling instant hash inversion.

• Cryptographic Salt:

- A unique, cryptographically random string (minimum 16 bytes / 128 bits) generated per user and stored alongside the password hash in the database.
- Eliminates Rainbow Tables: Attackers must recompute tables specifically for each individual user's salt.
- Disguises identical passwords: Two users with the exact same password produce completely distinct hashes.

• Cryptographic Pepper:

- A secret server-side key concatenated with the password before hashing, stored in an isolated Hardware Security Module (HSM) or environment variable away from the database.
- If the user database is dumped, hashes cannot be cracked without the secret pepper.

Slow Key Derivation Functions: Argon2id, bcrypt & PBKDF2

Memory-Hard Functions That Neutralize GPU/ASIC Cracking

• Why SHA-256 and MD5 Fail for Passwords: Fast general-purpose hashing functions allow specialized GPU clusters to test over 100 billion guesses per second.

• Adaptive Slow Hashing Functions:

- Parameterized Work Factor: Work factor (cost / iterations) can be increased over time as hardware advances without invalidating existing passwords.
- bcrypt (Niels Provos & David Mazières): Based on Blowfish key schedule; incorporates 128-bit salt and configurable cost factor 2^{cost}.
- PBKDF2 (Password-Based Key Derivation Function 2): Applies HMAC pseudorandom function repeatedly (typically 600,000+ iterations for SHA-256).
- Argon2id: Winner of the Password Hashing Competition; memory-hard algorithm that forces cracker hardware to allocate large RAM blocks per guess, making massive GPU parallelization economically and physically impossible.

Windows Security: SAM Database & LSASS Process

Local Account Storage, Password Hashes, and Memory Security

• Security Account Manager (SAM):

- Registry hive stored in `C:\Windows\System32\config\SAM` storing local user accounts and NTLM password hashes.
- Locked exclusively by the kernel during OS runtime; cannot be opened or copied by standard user processes.
- Protected with Syskey / System startup key encryption.

• Local Security Authority Subsystem Service (`lsass.exe`):

- Core Windows process enforcing security policies, verifying user credentials, and handling Kerberos and NTLM authentication tickets.
- Credential Dumping Threat: Attackers utilizing tools like Mimikatz inject into `lsass.exe` memory to dump plaintext passwords and Kerberos tickets.
- Modern Mitigation: Windows Credential Guard runs LSASS in an isolated virtualized container (VBS - Virtualization-Based Security) inaccessible to the host OS kernel.

Windows User Account Control (UAC) & Integrity Levels

Enforcing Least Privilege in Desktop Client Environments

• User Account Control (UAC): Prevents unauthorized system modifications by running administrative accounts with standard user privileges by default.

• Dual Access Tokens: When an administrator logs on, Windows issues two security tokens: a filtered standard user token and a full administrator token.

• UAC Elevation Prompt: Switches to the Secure Desktop (isolated from malware hooks), requesting explicit human consent or credential entry.

• Windows Mandatory Integrity Levels (MIC):

- Untrusted / Low: Sandboxed web browser processes (Edge, Chrome tabs).
- Medium: Standard interactive user applications and documents.
- High: Elevated administrative processes.
- System: Operating system kernel and critical drivers.
- Rule: A process at a lower integrity level CANNOT write to or inject code into an object at a higher integrity level.

Enterprise Authentication: Kerberos Protocol

Ticket-Based Single Sign-On in Active Directory Domains

- Kerberos (RFC 4120): The default network authentication protocol in Windows Active Directory and enterprise Linux domains.
- Key Distribution Center (KDC): Runs on Domain Controller, consisting of Authentication Server (AS) and Ticket-Granting Server (TGS).
- Step-by-Step Ticket Exchange Sequence:
  1. AS-REQ / AS-REP: User authenticates; KDC returns a Ticket-Granting Ticket (TGT) encrypted with KDC secret key.
  2. TGS-REQ / TGS-REP: User presents TGT to request access to a specific service (e.g., SUA file share); KDC issues a Service Ticket.
  3. AP-REQ: User presents Service Ticket to target server; server verifies ticket without ever seeing the user's password.
- Advantages: Passwords are NEVER transmitted across the network; mutual authentication prevents server spoofing; tickets expire automatically.

Role-Based Access Control (RBAC) Architecture

Enterprise Permission Management for University Systems

• Core Philosophy: Access permissions are assigned to organizational job roles rather than directly to individual user accounts.

• Three Core Rules:

- 1. Role Assignment: A subject can execute a transaction only if assigned an authorized role.
- 2. Role Authorization: A subject's active role must be authorized for that subject.
- 3. Permission Authorization: A subject can execute a transaction only if the transaction is authorized for the subject's active role.

• Role Hierarchy in SUA Academic Systems:

- `Student`: Read own grades, submit assignments, browse course materials.
- `Lecturer`: Enter/edit continuous assessment marks for assigned courses, upload compendia.
- `Head of Department (HOD)`: Approve marks, assign course teaching allocations.
- `Examination Officer`: Decrypt examination master files, lock final semester results.

Linux Pluggable Authentication Modules (PAM)

Modular Framework Decoupling Applications from Authentication

• PAM Architecture: Provides a centralized API allowing system programs (`login`, `sshd`, `sudo`, `su`) to authenticate users via pluggable shared libraries without modifying application source code.

• Four Management Groups in `/etc/pam.d/`:

- `auth`: Verifies user identity (checks password, biometrics, or hardware token).
- `account`: Enforces account restrictions (password expiration, login hour limits, access bans).
- `password`: Updates user authentication credentials (enforcing complexity rules via `pam_pwquality`).
- `session`: Manages user environment setup and teardown (mounting home directories, logging login audit records).

• Control Flags: `required` (must succeed, continues through stack), `requisite` (must succeed, fails immediately), `sufficient` (success grants access if no prior required failed), `optional`.

Physical Port Security & DMA Attack Mitigations

Hardening External Expansion Buses Against Hardware Exploits

• Physical USB Threats: BadUSB (microcontroller simulating human keyboard typing keystrokes at 1,000 WPM), Rubber Ducky, USB killer devices injecting high-voltage discharge into data lines.

• Direct Memory Access (DMA) Attacks:

- High-speed expansion interfaces (Thunderbolt, PCIe, FireWire) possess direct access to system DRAM without CPU mediation.
- Threat: An attacker connects a PCIe hardware sniffer to read encryption keys directly out of RAM within seconds.

• Hardware Defense - Kernel DMA Protection & IOMMU:

- Input-Output Memory Management Unit (IOMMU - Intel VT-d / AMD-Vi): Remaps device memory accesses through dedicated page tables.
- Blocks unauthorized DMA: High-speed peripherals cannot access unallocated system memory or kernel regions, neutralizing physical Thunderbolt snooping attacks.

Remote Attestation via TPM 2.0

Cryptographic Verification of System Integrity Across Networks

• The Integrity Challenge: How can a centralized university management server know that a remote field laptop at SUA Mazimbu has not been compromised by a rootkit?

• Remote Attestation Sequence:

1. Remote laptop boots: Firmware, bootloader, kernel, and security drivers are measured and hashes extended into TPM PCRs.

2. Central Attestation Server generates a cryptographic Nonce (random challenge string) to prevent replay attacks.

3. Laptop TPM quotes PCR contents: Combines PCR hashes with the nonce and digitally signs the payload using its private Attestation Identity Key (AIK).

4. Server verifies the AIK signature using the laptop's public certificate and compares PCR values against a database of known-good 'Gold Masters'.

5. Access Decision: If PCRs match, network access is granted; if unauthorized code was executed, access is quarantined immediately.

Secure Boot Key Revocation: Managing the dbx

Responding to Vulnerable Bootloaders and Stolen Certificates

• The Vulnerability Window: If a legitimate signed bootloader is found to have a security flaw (e.g., 'BootHole' CVE-2020-10713 in GRUB2), attackers can use that vulnerable binary to bypass Secure Boot.

• Forbidden Signatures Database (`dbx`):

- A cryptographically signed blocklist embedded in UEFI NVRAM containing SHA-256 hashes of compromised EFI executables and revoked vendor signing keys.

- If an EFI binary's hash is listed in `dbx`, UEFI firmware halts execution immediately, even if the file is signed with a valid key in `db`.

• Update Distribution: `dbx` updates are signed with the vendor's KEK and delivered through operating system security updates (Windows Update / Linux `fwupd`).

Enterprise Key Escrow: Managing BitLocker Recovery Keys

Preventing Catastrophic Lockout in Corporate Deployments

• The Recovery Dilemma: If motherboard hardware is replaced, firmware is updated, or TPM state is cleared, BitLocker locks the drive and demands the 48-digit numerical Recovery Key.

• Enterprise Key Escrow Architecture:

- In an enterprise environment (SUA administration), recovery keys must NEVER be left to individual end-users to record on paper.

- Active Directory Domain Services (AD DS): BitLocker policies configured via GPO automatically back up the 48-digit recovery password and TPM owner information into AD computer objects.

- Cloud Escrow (Microsoft Intune / Entra ID): Recovery keys vaulted securely in encrypted cloud directories accessible only to authorized IT administrators via multi-factor authentication.

- Self-Service Portals: Allows authenticated users to look up their specific device recovery key following identity verification.

Physical Media Destruction: Degaussing & Disintegration

NIST SP 800-88 'Destroy' Standards for End-of-Life Assets

• When Logical Sanitization is Insufficient: Decommissioning drives containing classified national research, examination master keys, or personal health records.

• Degaussing (Magnetic Media Only):

- Subjecting magnetic HDDs or tapes to an intense magnetic pulse (measured in Oersteds / Gauss, typically > 10,000 Gauss).
- Eliminates magnetic domain alignments permanently and destroys factory servo tracks, rendering the drive completely inoperable and unreadable.
- WARNING: Degaussing has ZERO effect on Solid-State Drives (NAND flash stores charge, not magnetic polarity!).

• Disintegration & Shredding (SSD & Media Universal):

- Physical mechanical shredders grinding drive electronics down into microscopic fragments (NIST specifies particle size ≤ 2 mm for SSD chips).
- Ensures that no single silicon NAND die remains intact.

Topic 3: Key Takeaways & Synthesis Matrix

Summary of PC Security Controls for Examination Mastery

• Storage Security: ATA passwords protect hardware controllers; WDE (BitLocker/LUKS) protects logical data at rest via TPM key sealing.

• UEFI vs BIOS: UEFI provides 64-bit protected execution, GPT partition table (>2TB), and cryptographic Secure Boot.

• Secure Boot Chain: Platform Key (PK) → Key Exchange Key (KEK) → Allowed Database (db) authenticates bootloader and kernel.

• TPM 2.0: Hardware Root of Trust providing Platform Configuration Registers (PCRs) for Measured Boot and cryptographic unsealing.

• Password Engineering: Entropy H = L · log₂(N); length provides exponentially greater security than complex character shuffling.

• Access Control: DAC grants discretionary owner control; MAC (SELinux) enforces kernel-level mandatory labels; RBAC maps to job roles.

Review Quiz & Knowledge Check

Self-Testing Key Security Principles

1. If a laptop with an unencrypted drive and a Windows login password is stolen, how can an attacker read the files?
2. What is the fundamental function of the Forbidden Signatures Database (dbx) in UEFI Secure Boot?
3. Calculate the entropy of a 10-character password using only decimal digits 0-9. (Ans: 10 · log₂(10) ≈ 33.2 bits).
4. Differentiate between Discretionary Access Control (DAC) and Mandatory Access Control (MAC).
5. Why does modern SSD data sanitization rely on Cryptographic Erase rather than multi-pass magnetic overwriting?

Reading Assignments & Homework Notice

Preparation for Next Lecture & Continuous Assessment

- Required Readings:
  - Stallings, W. - Cryptography and Network Security (8th Ed.), Chapters 1, 11 & 18.
  - NIST Special Publication 800-88 Revision 1: Guidelines for Media Sanitization.
  - UEFI Specification Version 2.10, Chapter 32 (Secure Boot).
- Homework Assignment 3 Notice:
  - Available on SUA Moodle / Assignment directory: `BIT_111_Assignment_3.pdf`.
  - Total Allocation: 100 Marks (Covers Storage Security, Entropy Calculations, and Exam Lab Hardening).
  - Submission Deadline: End of Week 6 by 17:00 EAT.
- Next Lecture Preview: Topic 4 — Functions and Types of Operating Systems (DOS, Linux, Windows, Scheduling).